

Задание 2. Анализ инцидентов ИБ

Отчетный период: [месяц]

Источник: фишинговая кампания

Ссылки на разделы:

[1. Инцидент № 1](#)

[2. Инцидент № 2](#)

[3. Инцидент № 3](#)

1. Инцидент № 1

1.1 Критичность

Уровень риска

Высокий

Обоснование

- Скомпрометированы учетные данные руководителя. У пользователя есть доступ к VPN (vpn-default, vpn-common-services).
- Членство в группах доступа к 1С ЗУП и 1С Документооборот создает риски утечки ПДн, возможно в большом объеме.
- Доступ к файловым ресурсам (gg_fserv_*) и почтовым сервисам (Yandex360/all_office@clinic.ru) расширяет поверхность атаки и несанкционированного доступа.
- Однако УЗ не содержит привилегий администрирования ИТ-инфраструктуры, что не позволяет оценить инцидент как критический.
- Особый риск может представлять членство пользователя в группе GG_proxy_exclude, если политика группы дает возможность обходить технологии фильтрации на шлюзе.

1.2 Возможные последствия

Initial Access

- **T1078 Valid Accounts + T1133 External Remote Services:** Использование скомпрометированных учетных данных для авторизации на внешнем периметре - подключение к корпоративной сети через VPN (vpn-default) и доступ к корпоративной почте через облако (GG_Yandex_360).

Persistence

- **T1114.003 Email Forwarding Rule:** создание правил пересылки почты

Discovery	– T1135 Network Share Discovery: Исследование корпоративной сети и обращение к сетевым папкам (gg_fserv_Katar, gg_fserv_expluatacia, GG_Profiles_Drive) для поиска проектов, планов помещений и инженерных схем торговых точек. – T1087 Account Discovery: Обращение к системе 1С ЗУП для изучения организационной структуры, сотрудников и руководства для планирования дальнейших векторов атак.
Collection	– T1213 Data from Information Repositories: выгрузка из 1С Документооборот (договоры, сметы и тд) и 1С ЗУП (ПДн сотрудников, окладыко). – T1114 Email Collection: Доступ к корпоративной почте через Yandex 360 для сбора деловой переписки с партнерами и внутренним руководством.
Lateral Movement	– T1534 Internal Spearphishing: Рассылки вредоносного ПО или фишинговых писем от лица руководителя, что имеет высокую вероятность успеха.
Exfiltration	– T1567 Exfiltration Over Web Service / T1048 Exfiltration Over Alternative Protocol: Выгрузка собранных данных на внешние серверы с пропуском трафика мимо стандартных правил прокси-сервера, благодаря нахождению пользователя в группе GG_proxy_exclude.
Основной риск	– Утечка ПДн и коммерческой тайны.

1.3 Приоритет реагирования

Немедленная реакция	☒
Привлечение ИТ службы	☒ для смены учетных данных в AD
Уведомление руководства	☐
Расследование	☒

1.4 Меры и сроки устранения

Мера	Срок
Блокировка учетной записи в AD и Yandex 360	Немедленно (до разрыва сессий и смены пароля)
Принудительный разрыв активных VPN-сессий пользователя	Немедленно
Завершение активных сессий в 1С ЗУП и 1С Документооборот	До 30 минут
Смена пароля пользователя в AD и почте	До 1 часа
Анализ журналов почтового ящика (вход, правила пересылки, удаление/отправка писем)	До 3 часов
Аудит логов межсетевого экрана и VPN (поиск аномальных подключений)	До 4 часов
Анализ действий пользователя в 1С за последние 24 часа	До 4 часов
Подготовка итогового отчета о расследовании	До 2 раб. дней

1.5 Пост-инцидентные рекомендации

Аудит прав доступа	Исключить пользователя из группы GG_proxy_exclude. Практика полного отключения веб-фильтрации для не-ИТ сотрудников несет недопустимые риски эксфильтрации данных. Если доступ в обход прокси требуется для работы профильного ПО, необходимо настроить точечные исключения.
MFA	Внедрить MFA при подключении по VPN и почты, если она доступна извне.

Ограничение массовых рассылок	Настроить модерацию писем, отправляемых на глобальные списки рассылки (all_office@clinic.ru), чтобы исключить возможность веерной отправки вредоносных писем по всему центральному офису.
Точечное обучение	Назначить обучение на сотрудника или ввести компенсирующие меры
Превентивная защита	Зафиксировать выполненные меры и инцидент в playbook для сохранения работы по инциденту в базу знаний

2. Инцидент № 2

2.1 Критичность

Уровень риска

Критический

Обоснование

- Скомпрометирована УЗ сотрудника первой линии ТП ИТ. Учетная запись имеет расширенный доступ в инфраструктуре:
- административный доступ на терминальных серверах: RDS-SRV-C-ADM, RDS-SRV-S-ADM, RDS-SRV-A-ADM
- является членом группы локальных администраторов (ekb_local_admins)
- потенциальный контроль на VDI инфраструктурой (LL_vcenter_First_line, VDIbeeline_Administrator, vpn-vdi-access)
- sudo-права на управление контейнерами (ds_restart_containers_sudo) и доступ к core-серверам (LL_Firstline_Admin_Core_Servers);
- доступ к инженерным системам поддержки.
- Совокупность административных прав и роль сотрудника с возможностью запрашивать сбросы паролей у других сотрудников квалифицирует инцидент как критический с потенциалом развития атаки до масштабной компрометации инфраструктуры.

2.2 Возможные последствия

Initial Access

- **T1078 Valid Accounts + T1133 External Remote Services:** Авторизация с полученными учетными данными через VPN (vpn-it-support, vpn-co-services), RDS (RDS-RemoteSession, RDS_RemoteApp_Access), корпоративные порталы (Bitrix, Yandex 360).

Execution	– T1059 Command and Scripting Interpreter: Выполнение команд на серверах с административными правами через RDS-сессии администрирования (RDS-SRV-*-ADM).
Persistence	– T1136 Create Account: Создание дополнительных учетных записей на подконтрольных серверах и в сервисах (GitLab, Grafana, OTRS). – T1053 Scheduled Task/Job: Создание задач на серверах RDS. – T1505.003 Web Shell: Закрепление в веб-сервисах при наличии административного доступа.
Credential Access	– T1555 Credentials from Password Stores: Дамп учетных данных на серверах, администрируемых через RDS-SRV-*-ADM; Сервер терминального доступа имеет большое количество сессий множества пользователей, так что компрометация одного RDS-сервера дает материалы для массового сбора учетных данных.
Discovery	– T1087 Account Discovery: разведка доменной инфраструктуры со штатных рабочих мест ИТ-поддержки, доступных через Confluence/Jira (документация инфраструктуры, схемы, пароли, токены) – T1087 Account Discovery: Обращение к системе 1С ЗУП для изучения организационной структуры, сотрудников и руководства для планирования дальнейших векторов атак.
Lateral Movement	– T1021 Remote Services: Перемещение между серверами по RDP.
Impact	– T1486 Data Encrypted for Impact: При развитии компрометации до уровня домена

реалистичен сценарий распространения шифровальщика.

- Основной риск
- Социальная инженерия: компрометация через запросы сброса паролей у сотрудников от имени ТП
 - Потенциальная утечка секретов и учетных данных с терминальных серверов
 - Администраторский доступ в инфраструктуре на локальных серверах и устройствах

2.3 Приоритет реагирования

Немедленная реакция	☒
Привлечение ИТ службы	☒
Уведомление руководства	☒
Расследование	☒

2.4 Меры и сроки устранения

Мера	Срок
Блокировка учетной записи в AD и Yandex 360, сервисные порталы	Немедленно (до разрыва сессий и смены пароля)
Принудительный разрыв активных сессий: VPN, RDS, VDI	Немедленно
Смена пароля пользователя в AD и почте	До 30 минут
Анализ журналов RDS-серверов (RDS-SRV-*-ADM) (сессии, команды, задачи, созданные УЗ в период инцидента)	До 4 часов
Анализ серверов на компрометацию: (локальные пользователи, задачи планировщика, службы, контейнеры)	До 1 раб. дня

Ротация секретов в vault-marketplaces-firstline, проверка журналов доступа к vault	До 4 раб. дня
Анализ журналов GitLab/Grafana/OTRS/Bitrix/Confluence (входы, изменения, созданные учетные записи и токены)	До 1 раб. дня
Анализ журналов vCenter/VDI на несанкционированные действия	До 1 раб. дня
Аудит исходящей почты ящика от имени техподдержки (рассылка фишинга)	До 4 часов
Уведомление руководства и владельцев затронутых систем	До 4 часов
Подготовка итогового отчета о расследовании	До 4 раб. дней

2.5 Пост-инцидентные рекомендации

MFA	Обязательная MFA для всех ИТ-учетных записей и для входов через vpn-it-support / RDS-администрирование в первую очередь. Для ИТ-персонала - аппаратные ключи (FIDO2) вместо push/SMS-факторов, чтобы повысить устойчивость к фишингу.
Разделение сред	Рабочая учетная запись первой линии не должна совмещать повседневные задачи и административные права (RDS-SRV-*-ADM, ekb_local_admins, sudo на контейнеры). Внедрить модель отдельных административных УЗ, чтобы фишинг персонального ящика не давал доступ к правам администратора серверов.
Секреты	Регулярная ротация секретов, Аудит выдачи доступа секретов и запрет их хранения в Confluence/Jira/GitLab.
SIEM	Настроить сбор событий в SIEM из нетипичных локаций/времени, создание локальных УЗ/задач на

RDS-серверах, создание новых токенов доступа, массовые операции.

РАМ	Внедрить контроль привилегий административных прав с журналированием сессий по запросу, вместо постоянного членства в группах ADM.
Точечное обучение	Назначить обучение на сотрудника или ввести компенсирующие меры, повторное моделирование через 1-2 месяца.
Превентивная защита	Зафиксировать выполненные меры и инцидент в playbook для сохранения работы по инциденту в базу знаний

3. Инцидент № 3

3.1 Критичность

Уровень риска

Средний

- Обоснование
- Скомпрометирована УЗ кладовщика с минимальным охватом инфраструктуры: корпоративная почта (Yandex 360), мобильная синхронизация (ActiveSync) и электронный документооборот Контур.
 - Факторы ограничивающие критичность: минимальные привилегии УЗ, наличие MFA, отсутствие удаленного доступа в сеть
 - Факторы не позволяющие оценить инцидент как низкий:
 - почтовый ящик - распространение фишинга от доверенных лиц;
 - документооборот Контура может содержать первичные документы, накладные.

3.2 Возможные последствия

- Initial Access
- **T1078 Valid Accounts:**
Вход в корпоративную почту, Yandex 360 и документообороту с украденными данными, при наличии 2FA вероятность понижается, но не нулевая (phishing reverse-proxy).
- Persistence
- **T1114.003 Email Forwarding Rule:**
Правила пересылки в почтовом ящике.
- Collection
- **T1114 Email Collection:**
Сбор переписок из почты
 - **T1213 Data from Information Repositories:**
Анализ электронного документооборота: накладные, акты, документы, подписанные ЭП.

- Impact – **T1565.001 Stored Data Manipulation:**
Модификация или фальсификация документов в ЭДО Контур, при наличии прав у пользователя.
- Основной риск – Нарушение цепочек поставок (изменение реквизитов контрагентов)
– Утечка малого объема ПДн из почтовых переписок

3.3 Приоритет реагирования

- Немедленная реакция ☐
- Привлечение ИТ службы ☒
- Уведомление руководства ☐
- Расследование ☒ ограниченное: действия в почте, ЭДО

3.4 Меры и сроки устранения

Мера	Срок
Смена пароля пользователя в AD, почте и ЭДО	До 30 минут
Анализ журналов почты (отправленные письма, правила пересылки)	До 3 часов
Анализ действий в ЭДО: (доставка, подписание, изменение документов)	До 1 раб. дня
Подготовка итогового отчета о расследовании	До 2 раб. дней

3.5 Пост-инцидентные рекомендации

- Двухсторонняя проверка документов Регламент верификации документов и реквизитов при обмене с контрагентами через ЭДО; порядок сообщения о подозрительных письмах.
- Точечное обучение Назначить обучение на сотрудника, повторное моделирование через 1-2 месяца.